

TLP: CLEAR

CAMPAIGN ANALYSIS G1024

Akira.

A ransomware operation that has taken a quarter of a billion dollars without needing a single zero-day — every documented way in is a remote-access appliance protected by a password alone.

SUBJECT TYPE Campaign · actor + CVEs	ATTRIBUTION eCrime, financially motivated	FIRST OBSERVED March 2023
ASSESSED RISK Critical	REPORT DATE 16 August 2026	

Akira is a ransomware-as-a-service operation that has extorted roughly a quarter of a billion dollars from more than 250 organisations since March 2023 without ever needing a zero-day. It gets in through remote-access appliances — two Cisco flaws, one SonicWall flaw, all patched long before it used them at scale — or, most often, by simply logging in to a VPN account that has only a password. It steals data first, deletes the backups, then encrypts at hypervisor level, and since October 2023 it has sometimes skipped the encryption entirely and extorted on the stolen data alone.

Your exposure is set by your remote-access authentication, not your industry. Manufacturing is the most-targeted sector and healthcare, education, professional services and construction all sit inside the observed victim profile — but the selection is opportunistic. A mid-sized manufacturer with enforced phishing-resistant MFA is a harder target than a large enterprise carrying one legacy appliance with single-factor logon.

Only four of the thirteen intrusion phases are addressed by patching. The flow's handoff line marks where the vulnerabilities stop contributing. Everything below it — credential theft, killed EDR, backup deletion, encryption — follows from any foothold at all, including a phished password.

A successful MFA event is not evidence the account is safe. In the SonicWall campaign operators enrolled their own TOTP token through an enrolment portal exposed on port 4433, so the second factor was satisfied legitimately. Audit existing MFA registrations for devices nobody recognises; enforcement alone did not stop this.

Backups are attacked with credentials taken earlier in the same intrusion. Veeam credentials are harvested during credential access and used to delete backups before any encryptor runs. Offline or immutable copies held outside domain trust are what break that sequence — ordinary backups do not survive it.

Detection built on the encryptor will age out. Four payloads — C++ Akira, Rust Megazord, Akira_v2, and a Nutanix AHV build — have run down one unchanged path. The path is the durable detection surface; the file is not. And where the operation runs extortion-only, no encryptor appears at all.

Three years of the same way in

Akira is a ransomware-as-a-service operation first observed in **March 2023**, tracked by MITRE as G1024 ¹ and by vendors as GOLD SAHARA, PUNK SPIDER, Howling Scorpious and Storm-1567. It runs a double-extortion model: affiliates steal data before encrypting it, then name victims on a Tor leak site styled after 1980s green-screen terminals, from which the operation takes its name ⁴. Reporting links its tooling and infrastructure to the defunct Conti operation, though that connection is consistently described as an *assessed association* rather than an established one ⁷.

The defining characteristic is that Akira **rarely needs a novel exploit**. The recurring entry point across three years of reporting is a remote-access VPN protected by a password alone, reached either with credentials acquired beforehand or through a known flaw in the appliance itself ³. Every CVE attributed to the group sits in an internet-facing edge device — Cisco ASA and FTD, SonicWall SonicOS — and none is a zero-day. For a defender this inverts the usual priority: the control that most reliably stops an Akira intrusion is multi-factor authentication on remote access, not a faster patch cycle.

The tradecraft after entry is consistent enough across engagements to read as a documented playbook. Credentials are harvested with Mimikatz, LaZagne, LSASS memory dumps via `comsvcs.dll`, `ntdsutil` against NTDS.dit, Veeam credential-dumping scripts and Kerberoasting. Persistence comes from newly created domain accounts — one recurring name is `itadm` — services registered with `nssm.exe`, and registry changes that hide those accounts from the logon screen ³. Defensive controls are removed rather than evaded: the vulnerable Zemana antimalware driver is loaded to terminate protection from kernel mode, Windows Defender is disabled through PowerShell, and vendor uninstall tools are turned against the products they belong to ⁴. Data leaves through rclone, WinSCP, WinRAR, FileZilla and MEGA — 483 GB in one recorded engagement — and backups are deleted or stopped before any encryptor runs ³.

Activity, oldest first

2023-03

Akira emerges as a distinct ransomware operation

Operations begin against small and mid-sized businesses. Affiliates gain entry by logging in to VPN accounts that lack multi-factor authentication, using credentials acquired beforehand, then steal data before deploying a C++ encryptor built on ChaCha20 and KCipher2 with RSA key wrapping. Victims are published on a Tor leak site. [1](#) [3](#) [4](#)

2023-08

Megazord Rust encryptor introduced

Some intrusions begin deploying Megazord, a Rust-based encryptor that appends `.powerranges` to encrypted files and requires a password supplied at runtime before it will execute. Its ransom note points at the same negotiation site as Akira, tying both payloads to one operation. Talos incident responders record the move to Rust as a deliberate rewrite away from the original C++ and Crypto++ codebase rather than a new family. [4](#) [6](#) [7](#)

2023-09

Cisco ASA remote-access VPN exploited

Affiliates exploit **CVE-2023-20269** in Cisco ASA and FTD to brute-force valid credentials against the remote-access VPN and establish clientless SSL VPN sessions through default connection profiles. **CVE-2020-3259**, an information-disclosure flaw in the same appliances that leaks memory contents to unauthenticated crafted GET requests, is named alongside it as a route to harvesting the credentials that make the first step work. Cisco ASA SSL VPN and AnyConnect endpoints without MFA remain the most common way in. [3](#) [4](#) [8](#) [9](#)

2023-10

Shift to extortion-only operations

Intrusions are observed in which data is archived with WinRAR and moved out using rclone, WinSCP and MEGA cloud storage — 483 GB in one engagement — and the victim is then extorted **without any encryptor being deployed at all**. Dwell time across engagements ranges from under a day to 25 days. [3](#)

2024-04

Joint international advisory published

The FBI, CISA, Europol EC3 and NCSC-NL publish AA24-109A. It documents **Akira_v2**, a Rust rewrite of the Linux and ESXi encryptor that accepts runtime arguments to target VMware ESXi virtual machine disk files, restrict execution to virtual machines only, stop running VMs before encrypting, set the encryption percentage and control CPU threading. [2](#) [4](#)

2024-11

Assessed among the five most active ransomware operations

Unit 42 assesses the group as consistently ranking in the top five most active ransomware operations. Affiliates are recorded creating new domain accounts for persistence, dumping LSASS through `comsvcs.dll`, Kerberoasting, abusing the Zemana antimalware driver to terminate endpoint protection, and building their own virtual machines on compromised hosts to run outside host-level monitoring. [4](#)

2025-08

SonicWall SSL VPN campaign begins

A surge of intrusions begins against SonicWall SSL VPN appliances, linked to **CVE-2024-40766**. Rapid7 records a consistent chain: access through the SSLVPN component, escalation to an elevated or service account, theft of files from network shares and file servers, deletion or stopping of backups, then encryption at the hypervisor level. [5](#) [10](#)

2025-09

MFA enrolment abused through the Virtual Office Portal

Where a username and password had already been exposed, operators enrol **their own MFA/TOTP token** through SonicWall's publicly reachable Virtual Office Portal on port 4433, converting a stolen password into a fully enrolled VPN identity that satisfies the MFA challenge legitimately. Over-provisioned SSLVPN Default Users Group membership is recorded as a recurring contributing misconfiguration. [5](#)

2025-11

Advisory reissued with a critical-infrastructure warning

The joint advisory is updated on 13 November 2025 with additional co-signers including DC3, HHS and European agencies, warning of an **imminent threat to critical infrastructure**. Operators are recorded establishing command and control through tunnelling utilities such as Ngrok to initiate encrypted sessions. The advisory records more than **250 affected organisations** and approximately **USD 244.17 million** in ransomware proceeds as of late September 2025. [2](#)

The payload keeps changing; the way in does not

Across three years Akira has rewritten its encryptor twice, added platforms from Windows to Linux, VMware ESXi and Nutanix AHV, and at times abandoned encryption entirely in favour of pure data extortion. What has not changed once is the entry point. Every documented intrusion begins at a remote-access service reachable from the internet and protected by a single factor — whether that factor is stolen, brute-forced through a Cisco flaw, or bypassed by enrolling a fresh token through a SonicWall portal the operator could reach without authenticating. An organisation that models Akira as a malware problem will keep buying the wrong control.

- 1 MFA on remote access stops more Akira intrusions than patching does.** Every CVE attributed to the group sits in an edge appliance and none was a zero-day; the recurring entry point is a VPN account protected by a password alone.
- 2 Enrolled MFA is not enforced MFA.** In the SonicWall campaign operators enrolled their own TOTP token through a publicly reachable portal, so the challenge was satisfied legitimately. A successful MFA event in the logs is not evidence the account is controlled by its owner.
- 3 Encryption is now optional.** Since October 2023 the group has run extortion-only intrusions in which nothing is encrypted. A recovery plan built entirely around restoring from backup answers only half of what this actor does.
- 4 Backups are a target before they are a remedy.** The observed chain deletes or stops backups as a deliberate step before encryptors run, and does so at hypervisor level where a single action reaches every guest at once.
- 5 Detection anchored to the encryptor will age badly.** C++ Akira, Rust Megazord, Akira_v2 and the Nutanix AHV build are four payloads on one unchanged intrusion path. Detection built on the path outlives detection built on the file.

Who this actor actually hits

Akira is opportunistic rather than strategic: it selects on exposure and ability to pay, not on sector. The levels below therefore track where victims have actually been observed, not which sectors sound most consequential.

Manufacturing		CRITICAL	Named as a primary target set by MITRE, CISA, Unit 42 and Sophos alike — the most consistently cited sector across three years of reporting.
Professional services and consulting		HIGH	Sits squarely in the observed SMB victim profile; named by both Unit 42 and Sophos among the recurring targets.
Education		HIGH	Named in Sophos victimology, and the sector's reliance on flat remote-access VPN estates matches the observed entry vector closely.
Healthcare		HIGH	The US Department of Health and Human Services co-signed the November 2025 advisory update, which is a direct signal of observed targeting.
Construction and engineering		HIGH	Listed by Unit 42 among the small and mid-sized business sectors the group concentrates on.
Government		MODERATE	Appears in Sophos victimology, but the victim profile skews strongly toward private-sector SMBs rather than public bodies.
Financial services		MODERATE	Plausible given the opportunistic targeting model, but no reviewed reporting places Akira in the sector specifically.

Energy and utilities



MODERATE

The November 2025 update frames a critical-infrastructure threat in general terms; reporting does not place Akira intrusions in energy specifically.

Aerospace and defence



LOW

Outside the documented pattern. The operation is financially motivated and selects organisations that pay quickly, not those with the strongest access controls.

 Critical — actively targeted  High — fits the victim profile  Moderate — plausible, not observed

 Low — outside the pattern  Minimal — no indication

Bottom line. Exposure to Akira is decided by the authentication on your remote-access estate, not by your industry. A mid-sized manufacturer with enforced, phishing-resistant MFA on every VPN account is a harder target than a large enterprise carrying one legacy appliance with single-factor logon — and the group has consistently gone for whichever it finds first.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report, [akira-G1024-attack-flow.html](#) .

What this analysis is built on

- 1 MITRE ATT&CK — Groups: Akira (G1024) — <https://attack.mitre.org/groups/G1024/>
- 2 CISA — #StopRansomware: Akira Ransomware (AA24-109A), updated 13 November 2025 — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a>
- 3 Sophos X-Ops — Akira, again: the ransomware that keeps on taking — <https://www.sophos.com/en-us/blog/akira-again-the-ransomware-that-keeps-on-taking/>
- 4 Palo Alto Unit 42 — Threat Assessment: Howling Scorpion (Akira Ransomware) — <https://unit42.paloaltonetworks.com/threat-assessment-howling-scorpion-akira-ransomware/>
- 5 Rapid7 — Akira Ransomware Group Utilizing SonicWall Devices for Initial Access — <https://www.rapid7.com/blog/post/dr-akira-ransomware-group-utilizing-sonicwall-devices-for-initial-access/>
- 6 Cisco Talos — Talos IR trends: BEC attacks surge, while weaknesses in MFA persist (Q1 2024) — <https://blog.talosintelligence.com/talos-ir-quarterly-trends-q1-2024/>
- 7 Trend Micro — Ransomware Spotlight: Akira — <https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-akira>
- 8 NVD — CVE-2020-3259 (Cisco ASA/FTD information disclosure, CVSS 7.5, CWE-200, in CISA KEV) — <https://nvd.nist.gov/vuln/detail/CVE-2020-3259>
- 9 NVD — CVE-2023-20269 (Cisco ASA/FTD VPN AAA separation, CVSS 9.1, CWE-863/CWE-288) — <https://nvd.nist.gov/vuln/detail/CVE-2023-20269>
- 10 NVD — CVE-2024-40766 (SonicWall SonicOS improper access control, CVSS 9.8, CWE-284, in CISA KEV) — <https://nvd.nist.gov/vuln/detail/CVE-2024-40766>

Confidence and sourcing. The chronology, tooling and victimology are drawn from vendor and government reporting and are stated as reported. The Conti lineage is an assessed association carried by multiple vendors, not an established fact, and is marked as such in the text. Sector risk levels are *analyst assessments*, not measured values; they deliberately share a colour ramp with CVSS severity but are rendered as meters rather than scores so the two are not confused. One sourcing limitation is worth stating plainly: the CISA advisory pages block automated retrieval, so the figures attributed to AA24-109A — the victim count, the proceeds total and the November 2025 Ngrok detail — were taken from summaries of that advisory rather than read from the advisory text directly. They should be confirmed against the primary before being quoted externally.

Pipeline. Step 1 of TI-Reporting. The companion ATT&CK flow report is built from the JSON handoff in `subjects/akira/handoff/` , of which this analysis produces `analysis.json` .

ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

CAMPAIGN FLOW G1024 · 3 CVES

Akira.

An extortion crew walking through **remote-access appliances** — two Cisco flaws and one SonicWall flaw, none of them a zero-day. The vulnerabilities buy the front door and a durable identity; every credential dump, killed EDR agent and hypervisor-level encryptor below that is Akira tradecraft that would follow from any other foothold.

ALSO TRACKED AS GOLD SAHARA PUNK SPIDER Howling Scorpion Storm-1567

EXPLOITS CVE-2020-3259 CVE-2023-20269 CVE-2024-40766

ATTRIBUTION eCrime · RaaS	ACTIVE SINCE March 2023	OBJECTIVE Extortion
ENTRY VECTOR Remote-access VPN	HIGHEST CVSS 9.8	CISA KEY 2 of 3

Three doorways, two vendors, no zero-days

These are alternative entry points, not a chain. Each is independently sufficient, each sits in an internet-facing remote-access appliance, and all three had patches available before Akira used them at scale.

CVE	CVSS	EXPLOITATION	CWE	WHAT IT GIVES THE ACTOR
CVE-2024-40766	9.8	KEV	CWE-284	Unauthenticated reach into the SonicOS SSLVPN component across Gen5, Gen6 and Gen7 firewalls. The entry point for the campaign that began in August 2025.
CVE-2023-20269	9.1	IN THE WILD	CWE-863 CWE-288	Brute-forcing of valid VPN credentials without authenticating first, and clientless SSL VPN sessions through default connection profiles on Cisco ASA and FTD.
CVE-2020-3259	7.5	KEV	CWE-200	Appliance memory read back to unauthenticated crafted GET requests on the same Cisco ASA and FTD web services interface, surfacing the credentials the logon needs.

What patching buys you. It closes three specific doorways — and in the Cisco pair’s case it also stops the credential leak that feeds the doorway next to it. Both Cisco flaws are in the CISA KEV catalogue with remediation deadlines that have long passed, so an unpatched appliance here is an overdue action, not an open risk decision.

What it does not. It does not close the route Akira uses most often, which involves no exploitation at all: logging in to a VPN account that has only a password. Nor does it touch anything below the handoff line in the flow — this actor’s tradecraft after entry does not depend on these vulnerabilities, so a patched estate is protected against *this doorway* rather than against this actor.

Four phases of doorway, nine of tradecraft

One path, entry to extortion. Phases 05 through 10 are an escalation loop rather than a straight line — discover, escalate, steal credentials, move, land somewhere new, repeat — and a vertical flow flattens that into a single pass. Read them as a cycle that runs again on each new host.

01



INITIAL ACCESS

Walk in through the remote-access edge

T1078

Valid Accounts — logs in to VPN accounts carrying no second factor, using credentials acquired before the intrusion begins. This is the most common route across three years of reporting and involves no exploitation at all.

T1190

Exploit Public-Facing Application — sends crafted GET requests to the Cisco ASA and FTD web services interface to read back memory contents, harvesting the credentials that make the logon above work. [via CVE-2020-3259](#)

T1190

Exploit Public-Facing Application — abuses the AAA separation flaw on the same appliances to establish clientless SSL VPN sessions through default connection profiles. [via CVE-2023-20269](#)

T1190

Exploit Public-Facing Application — reaches the SonicOS SSLVPN component on Gen5, Gen6 and Gen7 firewalls through improper access control. [via CVE-2024-40766](#)

↓ A VPN session is a network position, not a command channel — the first thing needed is code running on a host.

02



EXECUTION

Run code with the tools already on the host

T1047

Windows Management Instrumentation — executes commands on remote hosts over WMI, including via [wmiexec](#).

T1059.001

Command and Scripting Interpreter: PowerShell — drives Defender configuration changes and domain enumeration through [Get-ADComputer](#).

T1569.002

System Services: Service Execution — runs payloads on remote systems as a service using [PsExec](#).

↓ Hands-on-keyboard work needs an interactive channel that survives the VPN session dropping.



COMMAND AND CONTROL

Hide the channel inside legitimate software

- T1219.002** Remote Access Tools: Remote Desktop Software — installs `AnyDesk` and `DWAgent`, so the operator channel is signed remote-support software rather than custom malware and rarely trips an endpoint rule.
- T1572** Protocol Tunneling — establishes encrypted sessions through tunnelling utilities such as `Ngrok`, recorded in the November 2025 advisory update.

↓ A channel dies with the account that opened it, so the next move is an identity of their own.



PERSISTENCE

Become a legitimate user of the estate

- T1098.005** Account Manipulation: Device Registration — where a password had already leaked, enrolls an operator-controlled MFA/TOTP token through the publicly reachable Virtual Office Portal on `port 4433`. The stolen password becomes a fully enrolled identity, and the logs record a *successful* second factor. [via CVE-2024-40766](#)
- T1136.002** Create Account: Domain Account — creates domain accounts that outlive the credentials used to get in. One name recurs across engagements: `itadm`.
- T1543.003** Create or Modify System Process: Windows Service — registers tooling as an auto-starting service with `nssm.exe`.

↓ The vulnerabilities' contribution ends here — they delivered a network position and, in the SonicWall case, an enrolled identity that satisfies MFA. Everything below is Akira's own tradecraft and would follow from any other foothold, including a phished password.



STEALTH

Put the new identity and the work out of sight

- T1564.002** Hide Artifacts: Hidden Users — edits the registry so the accounts just created do not appear on the Windows logon screen.
- T1564.006** Hide Artifacts: Run Virtual Instance — builds its own virtual machines on compromised hosts and works from inside them, where host-level endpoint monitoring cannot see the activity.

↓ Hiding only defeats a watching analyst; the sensors themselves still have to go before the noisy work starts.

06



DEFENSE IMPAIRMENT

Break the endpoint protection rather than evade it

T1685

Disable or Modify Tools — loads the vulnerable [Zemana antimalware driver](#) to terminate endpoint protection from kernel mode, disables Defender through PowerShell, and runs vendors' own uninstall utilities against their products. The controls are removed, not dodged.

↓ With nothing watching, the account can be traded up for one that reaches file servers and backups.

07



PRIVILEGE ESCALATION

Trade up to an account that reaches everything

T1078

Valid Accounts — moves from the initial VPN identity to an elevated or service account before touching file servers and backups. Reporting records the escalation as observed but not the mechanism, so this is mapped to the account use itself rather than to a named escalation technique.

↓ Elevated rights are what make the credential stores readable — dumping LSASS and NTDS.dit needs SYSTEM first.

08



CREDENTIAL ACCESS

Take the whole directory, not one password at a time

T1003.001

OS Credential Dumping: LSASS Memory — dumps LSASS with [Mimikatz](#), and separately by calling [comsvcs.dll](#) through [rundll32](#) to avoid bringing a known tool to the host.

T1003.003

OS Credential Dumping: NTDS — extracts the domain database with [ntdsutil](#), taking every domain credential at once rather than harvesting host by host.

T1110

Brute Force — brute-forces the Cisco remote-access VPN to identify valid credentials, which [CVE-2023-20269](#) permits without authenticating first. Note this one runs against the perimeter before access, not inside the estate. Reporting does not distinguish guessing from spraying, so it stays at the parent technique.

T1555

Credentials from Password Stores — harvests stored credentials with [LaZagne](#), and runs scripts specifically to pull credentials out of the Veeam backup infrastructure — the same systems it deletes later.

T1558.003

Steal or Forge Kerberos Tickets: Kerberoasting — requests service tickets and cracks them offline to recover service-account passwords.

↓ Domain credentials are what make domain-wide queries return anything, so enumeration comes after the dump rather than before it.



DISCOVERY

Map the estate with the credentials just taken

T1018

Remote System Discovery — identifies reachable hosts with ping sweeps and `Get-ADComputer` before choosing lateral movement targets.

T1046

Network Service Discovery — sweeps the internal network with `Advanced IP Scanner` and `NetScan`.

T1087.002

Account Discovery: Domain Account — enumerates accounts and directory structure with `AdFind`, `Get-ADComputer` and net commands.

↓ The map names the file servers and hypervisors worth reaching; the credentials open them.



LATERAL MOVEMENT

Reach the servers that hold the leverage

T1021.001

Remote Services: Remote Desktop Protocol — pivots between hosts over RDP using the credentials recovered from LSASS and NTDS.dit.

T1021.002

Remote Services: SMB/Windows Admin Shares — reaches administrative shares over SMB to move tooling and get onto file servers.

↓ From here the loop stops repeating and the operation turns to what it came for: the data itself.



COLLECTION

Gather and stage what the extortion will rest on

T1005

Data from Local System — collects files directly from compromised hosts.

T1039

Data from Network Shared Drive — takes files from network shares and file servers, which is where the data that carries the leverage actually lives.

T1560.001

Archive Collected Data: Archive via Utility — compresses the haul with `WinRAR` before moving it — 483 GB in one recorded engagement.

↓ The data has to be off the network before encryption starts, or the threat to leak it is empty.



EXFILTRATION

Move it out over channels that look like business traffic

T1048

Exfiltration Over Alternative Protocol — transfers over SFTP and FTP using `WinSCP` and `FileZilla`.

T1567.002

Exfiltration Over Web Service: Exfiltration to Cloud Storage — pushes the staged archives to `MEGA` using `rclone`.



With a copy of the data already gone, the encryption is leverage rather than the objective — and since October 2023 it is sometimes skipped entirely.



IMPACT

Remove the way back, then charge for it

T1489

Service Stop — `Akira_v2` takes a runtime argument to stop running virtual machines before encrypting them, so no guest holds a disk file open when it is rewritten.

T1490

Inhibit System Recovery — deletes or stops backups as a deliberate step before any encryptor runs, having already taken the Veeam credentials earlier in the intrusion.

T1486

Data Encrypted for Impact — encrypts at hypervisor level, so one action reaches every guest at once. Four payloads on this one path: C++ `Akira` using ChaCha20 and KCipher2, Rust `Megazord` appending `.powerranges`, Rust `Akira_v2` for Linux and ESXi, and a Nutanix AHV build.

T1657

Financial Theft — extorts payment by pairing stolen data with a Tor leak site. Some intrusions skip encryption altogether and extort on the data alone, which makes the leak site rather than the encryptor the real source of leverage.



Tactic icon and label warm as the intrusion advances



The spine tracks the same progression

T####

ATT&CK technique ID

via CVE

Enabled by the vulnerability — absent below the handoff

tool.exe

Observed tooling / IOC

Three encryptors and a toolkit of other people's software

Almost everything below the encryptors is legitimate administrative or support software. That is the detection problem in one line: the malicious half of this arsenal only appears at the very end, by which point the data has already left.

Akira

S1129

Original C++ encryptor using ChaCha20 and KCipher2 with RSA key wrapping

RANSOMWARE**Megazord**

S1191

Rust encryptor appending .powerranges, requires a password supplied at runtime

RANSOMWARE**Akira_v2**

S1194

Rust Linux and ESXi encryptor with runtime control over VM targeting and encryption percentage

RANSOMWARE**Zemana driver**

—

Vulnerable antimalware driver loaded to terminate endpoint protection from kernel mode

DEFENSE IMPAIRMENT**Mimikatz**

S0002

Credential dumping from LSASS memory

CRED ACCESS**LaZagne**

—

Harvests credentials from local password stores

CRED ACCESS**ntdsutil**

—

Built-in utility used to extract the NTDS.dit domain credential database

CRED ACCESS**AdFind**

—

Active Directory enumeration

DISCOVERY**Advanced IP Scanner**

—

Internal sweep for reachable hosts and services

DISCOVERY**NetScan**

—

Network service discovery alongside Advanced IP Scanner

DISCOVERY**Psexec**

—

Remote service execution for lateral movement

LATERAL MOVEMENT**AnyDesk**

—

Legitimate remote-desktop software used as the operator channel

REMOTE ACCESS

DWAgent

—

Second remote-support agent used for interactive control

REMOTE ACCESS

Ngrok

—

Tunnelling utility establishing encrypted C2 sessions

TUNNELLING

rclone

S1040

Bulk exfiltration to MEGA cloud storage

EXFILTRATION

WinSCP

—

Exfiltration over SFTP

EXFILTRATION

FileZilla

—

Exfiltration over FTP

EXFILTRATION

WinRAR

—

Archives collected data before transfer

COLLECTION

nssm.exe

—

Registers tooling as a persistent Windows service

PERSISTENCE

Close the doorways, then assume one was already open

Patching addresses phases 01 to 04. It does nothing about phases 05 to 13, and nothing about the entry route that needs no vulnerability at all.

Patch the three appliances

SonicOS to a build later than the affected Gen5, Gen6 and Gen7 releases listed below, per SonicWall advisory [SNWLID-2024-0015](#). Cisco ASA and FTD per the vendor advisories for both CVEs. Two of the three are in the CISA KEV catalogue with deadlines that have already passed.

PATCH

Enforce MFA, and audit what is already enrolled

This is the control that addresses the entry route patching cannot reach. Enforcement alone is not enough here: operators enrolled their own tokens through an exposed enrolment portal, so audit existing MFA registrations for devices nobody recognises and restrict enrolment to trusted networks.

MITIGATION

Rotate every credential the appliances held

[CVE-2020-3259](#) discloses memory contents rather than granting execution, and [CVE-2023-20269](#) allows offline discovery of valid credentials. Patching stops future leakage but does nothing about what already left. Rotate local appliance accounts, VPN accounts and any service account whose credentials transited them.

ROTATE CREDENTIALS

Reduce the SSLVPN blast radius

Remove over-provisioned membership of the SSLVPN Default Users Group, and take the Virtual Office Portal off the public internet — its reachability on port 4433 is what made operator-controlled MFA enrolment possible.

MITIGATION

Hunt for what is already inside

Search for domain accounts created outside change control, especially `itadm`; registry keys hiding accounts from the logon screen; `nssm.exe` service registrations; `AnyDesk`, `DWAgent` and `Ngrok` on servers that have no support contract reason to run them; unexpected virtual machines on hypervisors; and outbound `rc1one` traffic to MEGA. Patching closes the door; it does not remove anyone already through it.

HUNT

Make backups survive an operator with domain rights

The chain takes Veeam credentials during Credential Access and uses them to delete backups before encrypting. Offline or immutable copies, held under credentials that domain compromise does not yield, are what break that sequence.

MITIGATION

CVE	CVSS	AFFECTED	FIXED IN
CVE-2024-40766	9.8	Gen5 ≤ 5.9.2.14-12o · Gen6 ≤ 6.5.4.14-109n · Gen7 ≤ 7.0.1-5035	Per SNWLID-2024-0015
CVE-2023-20269	9.1	Cisco ASA / FTD remote-access VPN	Per Cisco advisory
CVE-2020-3259	7.5	Cisco ASA / FTD web services interface	Per Cisco advisory

What this mapping is built on

- 1 MITRE ATT&CK — Groups: Akira (G1024) — <https://attack.mitre.org/groups/G1024/>
- 2 CISA — #StopRansomware: Akira Ransomware (AA24-109A), updated 13 November 2025 — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a>
- 3 Sophos X-Ops — Akira, again: the ransomware that keeps on taking — <https://www.sophos.com/en-us/blog/akira-again-the-ransomware-that-keeps-on-taking/>
- 4 Palo Alto Unit 42 — Threat Assessment: Howling Scorpion (Akira Ransomware) — <https://unit42.paloaltonetworks.com/threat-assessment-howling-scorpion-akira-ransomware/>
- 5 Rapid7 — Akira Ransomware Group Utilizing SonicWall Devices for Initial Access — <https://www.rapid7.com/blog/post/dr-akira-ransomware-group-utilizing-sonicwall-devices-for-initial-access/>
- 6 Cisco Talos — Talos IR quarterly trends, Q1 2024 — <https://blog.talosintelligence.com/talos-ir-quarterly-trends-q1-2024/>
- 7 Trend Micro — Ransomware Spotlight: Akira — <https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-akira>
- 8 NVD — CVE-2020-3259 (Cisco ASA/FTD information disclosure) — <https://nvd.nist.gov/vuln/detail/CVE-2020-3259>
- 9 NVD — CVE-2023-20269 (Cisco ASA/FTD VPN AAA separation) — <https://nvd.nist.gov/vuln/detail/CVE-2023-20269>
- 10 NVD — CVE-2024-40766 (SonicWall SonicOS improper access control) — <https://nvd.nist.gov/vuln/detail/CVE-2024-40766>

Attribution confidence. Akira is *confirmed* by multiple independent primaries to have exploited all three vulnerabilities — Sophos and Unit 42 for the Cisco pair, Rapid7 for SonicWall — so the actor-to-CVE link is reported rather than inferred. The group's possible descent from Conti is a different matter: that is an assessed association carried by several vendors, not an established fact, and nothing on this page depends on it. Other actors also exploit these same CVEs, so patching priority should be driven by the vulnerability rather than by whether Akira is the actor you expect.

Scope note. The ATT&CK mapping behind this flow is *derived* from published reporting of Akira behaviour, not copied from a vendor's published mapping; every technique ID was verified against attack.mitre.org before use. Two tactics carry no techniques — **Reconnaissance** and **Resource Development** — because reporting says credentials were "acquired beforehand" without saying how. That absence reflects a gap in the published reporting, not evidence that Akira lacks the capability. Exact fixed build numbers could not be retrieved from the vendor advisories at build time, so the Fixed-in column points at the advisory rather than asserting a version; confirm the target build against the vendor before scheduling the change. Built from the JSON handoff in `subjects/akira/handoff/` .